

Historie a současnost



I když se hovořilo o počítačové infiltraci již v šedesátých letech minulého století ve spojitosti se sci-fi literaturou, v realu se s ní uživatelé mohli setkat až na začátku 80.let. Nejstarší infiltrací jsou trojské koně (trojan). Jde o programy, které se v minulosti snažily předstírat užitečnou činnost, ve skutečnosti ale škodily. Slovo “v minulosti” bylo použito úmyslně, jelikož i když jsou „trojani“ (resp. škodlivý software, který z tohoto pojmu vychází) stále na denním pořádku, obvykle se za nic užitečného nevzdávají.

Tehdejší se vydávaly, následuje několik příkladů:

- Rok 1985, trojský kůň EGABTR: Sliboval na tehdejších grafických adaptérech CGA lepší grafiku, než na moderních EGA adaptérech (dokázaly zobrazit fantastických 16 barev !). Ve skutečnosti smazal všechno na pevném disku a vypsal zprávu „Arf ! Arf ! Gotcha !“.
- Ze stejného období, „hra“ NUKELA. Ač se možná opravdu dala zahrát, po vypnutí již na disku nic nezůstalo.
- Přelom 80 – 90. let, trojské koně vydávající se za antivirové programy (místo hledání virů docházelo rovnou k mazání souborů na disku).

Vznik prvního viru (Brain) se datuje do roku 1986. Napsali ho dva bratři Basit a Amjads Farooq Alvi z Pakistánu – Lahore. Údajně ho dávali jako bonus cizincům, kteří si u nich v obchodě kupovali nelegální software. Nutno podotknout, že šlo o velice kvalitní dílo (využití techniky „stealth“), které způsobilo řadu lokálních epidemií. Brain byl boot virus, šířící se přes disketu, zapomenutou při startu PC v mechanice.

V roce **1987** se postupně objevilo několik virů. Lehigh, Stoned, Vienna, Cascade. Posledně jmenovaný doslova zlidověl, o jeho slavných padajících písmenkách na obrazovce slyšel kde kdo (podobně jako o viru žádající sušenku).

V roce **1988** se objevil slavný virus **Jerusalem** a jak píše Eugen Kaspersky ve své knize, ani řada odborníků nemohla uvěřit v existenci počítačových virů. Dokonce sám legendární Peter Norton (autor Norton Commanderu a produktů Symantec) prohlásil, že žádné viry neexistují. O to překvapující je, že o několik let později vytvořil Norton Anti-Virus...

Dalším významným datem je listopad 1988, kdy student Cornell University –Robert T. Morris vypustil do světa tzv. „Morrisův červ“. Červ napadl kolem 6000 unixových počítačů (údajně se mu to „nějak“ vymklo kontrole), blokoval tehdejší síť po dobu 36 hodin a nepřímo se tato událost dotkla miliónu lidí. Červ se dostal i do Lawrence Livermore National Laboratory, kde se pracovalo na utajovaném jaderném programu, do NASA a škody dosáhly výše 100 miliónů dolarů.

Rok 1988 zahájil i éru antivirových programů. Jedním z nejstarších je **McAfee VirusScan**, stejně jako Dr. Solomon AVTK. Druhý jmenovaný byl později odkoupen prvně jmenovaným.

V roce **1990** se začaly objevovat první **polymorfní viry**, tedy viry, u nichž vypadá každý exemplář odlišně „na venek“. Stávající antivirové společnosti musely vyvinout nové metody detekce, jelikož dosud spolehlivý způsob vyhledávání podle řetězců znaků nezabíral.

Velká spousta virů vznikala na území Bulharska. Z velké části celou produkci táhla osoba jménem „Dark Avenger“. Celkem se není čemu divit, že ve stejném státě vznikla i první **BBS** určená výhradně k výměně virů a zdrojových kódů. Kromě polymorfních virů se stále častěji objevovaly „stealth“ viry, tj. viry, které se dokáží maskovat v systému. Příkladem mohl být virus Frodo, který sledoval manipulaci se soubory a uživateli nebo antiviru „předhazoval“ nezávadné verze těchto, ve skutečnosti infikovaných souborů.

Ukázkový byl i první multipartitní virus Tequila v roce **1991**. Multipartitní viry dokážou napadnout systémové oblasti disku, ale i soubory. Tequila byla navíc polymorfní a pro jistotu i typu **stealth**.

Rok 1992 byl rokem generátorů. Běžný uživatel si tak mohl během několika sekund vytvořit vlastní virus. Stačilo jen nastavit parametry budoucího viru (způsob šíření, projevu apod.), stisknout tlačítko „generovat“ a

nový virus dle definovaných požadavků byl na světě. Obzvláště PS-MPC generátor se významně rozšířil, jinak si totiž nelze rozumně vysvětlit, proč vzniklo několik tisícovek virů, generovaných právě v PSMPC.

Během roku **1994** se objevila jedna z legend, virus **One_Half.3544.A**. Tento **silně polymorfní a multipartitní virus** ze Slovenska způsobil rozruch široko daleko. Ke slávě mu napomohla i skutečnost, že ho řada antivirů nedokázala stoprocentně detekovat. Dekryptovací algoritmus viru One_Half byl rozdělen na několik navzájem propojených „ostrůvků“, které byly „rozsety“ po infikovaném souboru. Tehdy velice rozšířený antivirus McAfee VirusScan nedokázal tuto překážku překonat ani o několik měsíců později a tak zůstávala značná část exemplářů mimo detekci. One_Half postupně kódoval obsah pevného disku podle určitého klíče, který si s sebou nesl. Pokud byl One_Half neodborně odstraněn (včetně tohoto klíče), znamenalo to i ztrátu zakódované části dat.

V srpnu **1995** se objevil první makrovirus Concept, šířící se v dokumentech vytvořených aplikací Microsoft Word. Makrojazyk v produktech Microsoft posílil natolik, že v něm bylo možné vytvořit i replikující se program – makrovirus. **Makrovirus** Konzept patřil ještě dlouhou dobu mezi nejrozšířenější viry a to i z důvodů, že tehdejší antiviry nebyly na takový typ infiltrace připraveny. Relativní klid panoval u majitelů českých verzí Wordu, jelikož lokalizace zasáhla i do názvů jednotlivých funkcí makrojazyka ! Concept a další velká skupina makrovirů tak nebyla schopna provozu pod českým Wordem. Tento „problém“ vyřešil až příchod MS Office 97...

Vývoj stále pokračoval a tak byly v roce 1998 k vidění první polymorfní 32-bitové viry pro Windows 9x – Win95/HPS a Win95/Marburg. V červu 1998 se začal šířit virus Win95/CIH, který byl později novináři pojmenován jako „**Černobyl**“. Virus „Černobyl“ byl zajímavý tím, že se každého 26. dubna (záleželo na variantě) pokusil přemazat paměť Flash BIOS na základní desce a kromě toho i část dat na disku. Pokud se přemazání paměti Flash BIOS zadařilo, pak nebyl počítač schopný provozu. Jinak než zásahem do hardwaru nebylo možné tento problém vyřešit. Virus Win95/CIH tak částečně narušil do té doby spolehlivé tvrzení, že hardware nelze virem poškodit. Na druhou stranu bylo možné tento problém ve většině případů efektivně vyřešit.

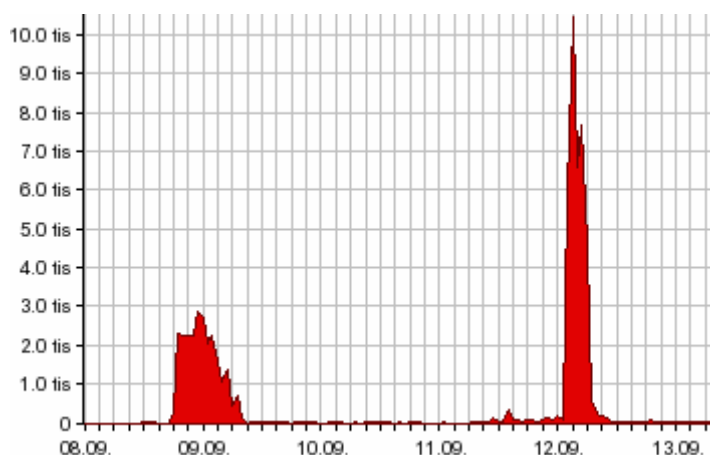
Ve stejném roce se začínají objevovat i první **skriptové viry**, konkrétně například **VBS/Rabbit** nebo **HTML/Internal**.

O rok později, tedy v roce 1999 se podobné skripty začínají objevovat v provedení „mass-mailing“. Začíná tak nová éra virů, šířících se elektronickou poštou. Jeden z prvních virů šířících se e-mailem byl Happy99, následován slavným makrovirem W97M/Melissa.A@mm. Jelikož se jednalo o makrovirus, logicky musel s každým šířením ukrást i nějaký ten dokument Wordu.

Současnost a budoucnost

Vývoj virů šířících se elektronickou poštou stále pokračuje. Zatímco ty nejstarší potřebovaly pro další šíření přímo aplikace Outlook, novějším to je úplně jedno. **Emailové adresy** budoucích obětí neshánějí jen v adresáři Outlooku, avšak na všech možných místech pevného disku. Obvykle prohledávají soubory s definovanou příponou (*.htm?, *.wab, *.txt...), takže e-mailových adres budoucích potenciálních obětí získají více než dostatek. K replikaci taktéž nepotřebují Outlook, prostě si s sebou „přinesou“ vlastní **SMTP** server, přes který vedou veškerou replikační činnost.

V současnosti jsou v módě „okleštěné“ varianty virů bez replikační části, díky čemuž je lze zařadit do kategorie trojanů, jenž jsou hromadně rozesílány přes dříve infikované PC ve světě Internetu₁₀ (podobně může být rozesílán i spam). Síla takových. Některé úspěšné viry mohou na infikované stroje vypouštět další aplikace, které umožní tuto činnost provádět a zneužívat tak infikované PC bez vědomí jeho uživatele (někdy je takový stroj označován pojmem „zombie“). Vypouštěná infiltrace je typu **backdoor nebo trojanproxy**.



Obrázek - typický průběh "spamování" virů (v tomto případě jde o dropper viru Win32/Bagle.B1) – několik obrovských vln (v tomto případě dvě) a pak mrtvo (svislá osa – počet infikovaných e-mailů zachycených na poštovním serveru, vodorovná osa – čas).

V této souvislosti je velice zajímavé konkrétní zjištění, že 15. února 2005 vypustil autor viru Bagle škodlivý kód s názvem SpamTool.Win32.Small.b (takto je detekován antivirem Kaspersky), který je určen k detailnímu průzkumu pevného disku a sběru nalezených e-mailových adres, které jsou následně odeslány autorovi Bagle prostřednictvím Internetu. Společnost Kaspersky Lab s tímto škodlivým kódem experimentovala a nechala prostřednictvím tohoto softwaru zaslat autorovi Bagle tisíce pokusných e-mailových adres. Zjistilo se, že nedlouho poté se v těchto schránkách objevila spousta nevyžádané pošty (spamu), zpráv typu "phishing" (podvodné e-maily vydávající se nejčastěji za bankovní instituce - obvykle se snaží vymáhat od klientů čísla kreditních karet) a další kousky virů Bagle. Verdiktem je, že autor viru Bagle si tak mohl otevřít byznys s prodejem těchto cenných informací - e-mailů dalším "kyberkriminálkům", kteří se živí zasíláním spamu, phishingu atd.

Stále větším problémem se stává spyware, adware apod. a co víc, tato „havěť“ se v řadě případů prolíná s trojany (typicky že trojan – downloader stáhne adware). S tímto souvisí i to, že např. detekci virů šířících se elektronickou poštou pokryjí nejznámější antiviry na 100% nejpozději během několika hodin po vypuknutí epidemie, což nelze zajistit u spyware, adware, dialer, downloader atd. Nejde totiž o globální problém (mluvíme-li o konkrétním kusu havěti). V praxi to může trvat několik měsíců, než bude konkrétní kousek detekován ze strany antivirových programů. Pokud jde o lokální problém a infikovaný soubor je ke stažení na nějaké konkrétní stránce Internetu, pravděpodobnost, že tam zavítá rovnou osoba ve spojení s AV společnostmi je mizivá.

Antivirový systém tak nemůže v žádném případě pokrýt detekcí celou "scénu". Často tak vzniká jev, že ač je antivirový program správně používán, jednoho dne (po aktualizaci) začne hlásit přítomnost aktivní havěti (operační paměť, soubor v adresáři Windows apod.). Podobný šok může nastat v případě, že se uživatel rozhodne PC zkontrolovat konkurenčním antivirovým produktem a nestačí se divit, kolik virů zrovna ten jeho stávající antivirový systém přehlédl. K tomuto pochopitelně nedojde, pokud bude uživatel dodržovat základní bezpečnostní pravidla

Počítačové viry

Viry pro DOS

Viry pro operační systém MS-DOS a jeho klony jsou nejstarší skupinou virů, do které patří i výše uvedené případy. Pojďme se na jednotlivé skupiny podívat podrobněji.

Boot viry

Tato první nejstarší skupina virů infikuje části nacházející se v určitých systémových oblastech disku. Těmito oblastmi mohou být: boot sektory disket a MBR(Master Boot Record) pevného disku. Napadením nějaké z těchto oblastí si boot virus zajistí svoje spuštění hned po startu počítače. Uvedené viry se chovají tak, že obvykle

přepíše svým vlastním kódem boot sektor, a původní přepsanou část boot sektoru uschovají na jiné místo disku. Příkladem mohou být sektory:

- v nevyužitých klastrech,
- v použitých klastrech (hrozí poškození původního obsahu),
- v systémových oblastech, které se nacházejí mimo aktivní oblast disku.

Taková virová infekce se potom šíří pomocí boot sektorů disket, které přišly do styku s nakaženým systémem. Operační systém DOS je pro ně totiž velmi výhodným hostitelem vzhledem k malé možnosti jeho kontroly a vzhledem k vysoké frekvenci používání těch nejjednodušších povelů jako je zápis a čtení z disku, kopírování disket, prohledávání obsahu adresáře atd.

Boot virus infikuje systém (tj. instaluje se do paměti a zapíše svoje tělo do MBR pevného disku při zavádění systému z infikované diskety. Virus se obvykle nainstaluje do paměti jako paměťově rezidentní, a jakmile dojde k novému zavádění systému, začne infikovat boot sektor disket, které nejsou ochráněny proti zápisu, a při tom přijdou do styku se systémem (například při kopírování na disketu apod.). V obou případech, jak u infekcí MBR nebo infekcí boot sektoru diskety, tento typ viru obvykle uloží původní boot sektor nebo tabulku rozdělení disku někam jinam na disketu či disk, ačkoliv to není vždy pravidlem. Jestliže virus zapíše původní boot sektor do kritické oblasti disku či diskety, jako je např. sektor obsahující část tabulky FAT, nebo hlavní diskový adresář, může dojít k tomu, že data na disku jsou navždy ztracena. Charakteristickým symptomem přítomnosti infekce bootovým virem, který lze zaznamenat i u neznámých boot virů je skutečnost, že kapacita systémové paměti, oceněná programem chkdsk či mem, je většinou nejméně o 1024 bytů menší, než jaká je ve skutečnosti paměť instalovaná v systému (tj. není 640 KB, ale třeba jen 639 KB).

Typické schéma činnosti jednoduchého boot viru

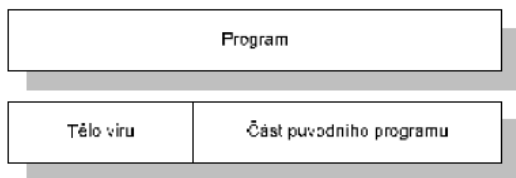
- Prvním krokem, kterým začíná kariéra takového viru v počítači je "nabootování" (tedy zavedení operačního systému) z diskety nakažené boot virem. V tomto okamžiku je virus zaveden do paměti a je mu předáno řízení. Není přitom nezbytné, aby disketa byla systémová; typickým zdrojem takovéto nákazy bývá disketa pro přenos dat, která zůstala omylem zamčena v mechanice při startu počítače.
- V další fázi si virus vyhlédne dostatečný velký kus paměti, který obsadí a překopíruje se do něj.
- Aby se kopie viru vytvořená v předchozím kroku dostala ještě ke slovu, musí virus následně změnit adresy některých systémových služeb (typicky diskové operace, někdy také časovač a jiné) tak, aby jejich vyvoláním došlo nejprve k aktivaci rezidentní části viru, která pak rozhodne, co se opravdu provede. Viry, které se takto usazují v paměti, nazýváme obecně rezidentní. Protože však každý boot virus je rezidentní už z principu, bývá zvykem tuto vlastnost již explicitně neuvádět.
- Následuje kontrola, zda je nakažen boot sektor pevného disku, ze kterého se běžně zavádí systém. Pokud je tento sektor "viru-prostý", virus jej okamžitě nakazí.
- Virus vyhledá na napadené disketě původní boot sektor, který načte do paměti, a spustí jej. Od této chvíle počítač pokračuje v běžném zavádění systému s tím, že virus je nadále aktivní v paměti připraven změnit běh věcí příštích.
- Pokud je po zavedení systému provedena jakákoli operace přistupující na disketu, je virus před provedením této operace aktivován (bod 3) a v případě, že tato disketa ještě není napadena, infikuje ji postupem analogickým bodu 4. Pokud jsou splněny zadané podmínky, provede virus připravenou akci (výpis textu, formátování disku apod.).

Souborové viry

Druhou a svého času nejrozšířenější skupinou jsou viry souborové. Jak již z názvu vyplývá, jejich hlavním hostitelem jsou soubory. Tyto viry bychom mohli dále třídit podle toho, jaké soubory při infekci napadají - v zásadě jsou to vždy proveditelné soubory, neboť cílem viru je, aby provedením hostitelského kódu došlo k rozmnožení virového kódu. Nejčastěji se tedy jedná o soubory spustitelné binární (COM, EXE...). Může se též jednat o souborové viry infikující dávkové soubory (BAT), ovladače (SYS). Mechanismus činnosti souborových virů je však podobný ve všech případech. Podle metody infekce můžeme souborové viry rozdělit na několik skupin:

Přepisující viry (overwriting viruses)

Nejjednodušší forma infekce, při níž dojde ke zničení (přepsání) části původního kódu programu tělem viru. Původní část je tak nenávratně ztracena a spuštěním souboru dojde pouze k aktivaci samotného viru snažícího se o další replikaci a nikoliv původního programu. Ve všech případech lze tyto viry označit za viry přímé akce, jelikož nejsou paměťově rezidentní.



Obrázek 5 Přepisující virus (overwriting virus).

Parazitické viry (parasitic viruses)

Jako parazitické viry jsou označovány ty, které se **regulérně připojí k proveditelnému hostiteli (souboru) bez toho, aby ho nějak trvale poškodily**. Obecně můžeme tuto skupinu rozdělit podle toho, kam je tělo viru z pohledu původního souboru umístěno:

- prepend (před)
- insert (v)
- append (za)

Posledně jmenovaný způsob je nejčastější. Při infekci je původní soubor upraven tak, aby po jeho následné aktivaci došlo jak k aktivaci viru, tak i původního programu.

Doprovodné viry (companion viruses)

Doprovodné viry jsou typem infekce, která nemění soubory, ani systémové oblasti disku. Doprovodné viry **„infikují“ soubory s příponou EXE tak, že vytvoří nový soubor obsahující samotné tělo viru a to se stejným názvem, ale s příponou COM** (příklad: máme soubor SPUST.EXE, virus vytvoří SPUST.COM). Podle priorit DOS dojde při volání daného souboru bez uvedení přípony nejprve k aktivaci toho s příponou COM a tím i k aktivaci viru. Záleží pouze na viru, zda po vykonání vlastních činností uvolní prostor i původně žádanému programu (souboru s příponou EXE). Alternativní metodou může být přejmenování původního EXE souboru změnou přípony a vložení se do nového souboru s původním názvem (například přejmenováním SPUST.EXE na SPUST.EXD a posléze vytvořením infikovaného souboru SPUST.EXE). Alternativou může být tzv. i „Path companion“, kdy se při infekci využívá priorit ve spojitosti s proměnnou DOS PATH (využíváno v autoexec.bat). Pokud se na disku nachází více souborů se stejným názvem (a klidně i příponou), je při volání určitého souboru spuštěn ten, který odpovídá požadavku a je nalezen v adresářích proměnné DOS PATH jako první. Proměnná DOS PATH je tedy jakýmsi seznamem adresářů, který je procházen od začátku do konce. Pokud je virus umístěn v určitém adresáři v horní části seznamu a stejně pojmenovaný soubor, který je žádán, v dolní polovině seznamu, pochopitelně dojde k aktivaci toho špatného – infikovaného.

Metody infekce COM a EXE souborů

Pod operačním systémem MS-DOS můžeme najít dva základní formáty spustitelných souborů. Jeden z nich má obvykle příponu COM, druhý EXE. Opět je nutno rozlišovat rozdíl mezi uvedenou příponou a skutečnou vnitřní strukturou souboru – formátem.

Soubor formátu COM

Nejednodušší formát spustitelného souboru. Jeho maximální velikost je omezena délkou paměťového segmentu, tj. 64 KB. Nemá žádnou hlavičku.

Soubor formátu EXE

Vnitřní struktura formátu EXE je o něco komplikovanější. Skládá se ze dvou částí, hlavičky (header) a vlastního kódu programu. Struktura hlavičky je následující:

Offset: Popis:

- 00h Signatura souboru (znaky „MZ“)
- 02h Velikost poslední stránky v B
- 04h Délka souboru v 512 B stránkách
- 06h Počet položek v relokační tabulce
- 08h Velikost hlavičky v 16 B
- 0ah Minimální potřebná paměť
- 0ch Maximální potřebná paměť

0eh Počáteční hodnota SS
 10h Počáteční hodnota SP
 12h Kontrolní součet
 14h Počáteční hodnota IP
 16h Počáteční hodnota CS
 18h Offset první relokační položky
 1ah Úroveň překrývání

Parazitické metody infekce

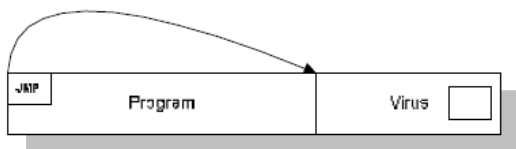
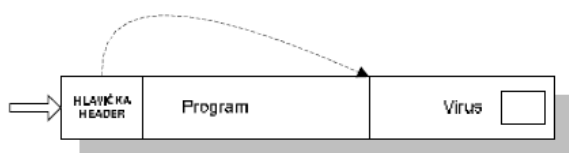


Schéma převzetí kontroly COM infektoru. Instrukce skoku **JMP** na samotném začátku předá řízení viru. V těle viru je zároveň uschován původní obsah oblasti, která byla nahrazena instrukcí skoku.

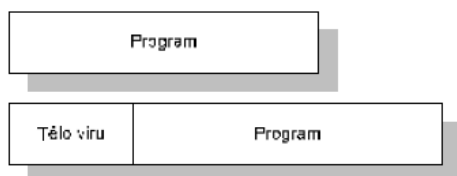
Nejzajímavější je bezpochyby infekce způsobená nedestruktivním virem z pohledu metody infekce spustitelných souborů. Nejednodušší je infekce souboru formátu COM, jelikož nemá žádnou hlavičku. Virus si tak pouze zapamatuje první tři bajty původního souboru (tj. uloží je na určité místo svého těla) a na jejich místo vloží instrukci skoku – **JMP**, směřující na počátek viru (hovoříme-li o skupině append). Pokud je infikovaný soubor spuštěn, dojde k aktivaci viru a následně i k rekonstrukci souboru do původního stavu právě díky uloženým třem bajtům. Zajišťuje se tak i spuštění původního programového kódu, který byl hlavní náplní souboru před infekcí. Mluvíme o tzv. předání řízení hostitelskému programu.



Obrázek - schéma převzetí kontroly EXE infektoru. Hodnota entry pointu (CS:IP) v hlavičce ukazuje na kód viru.

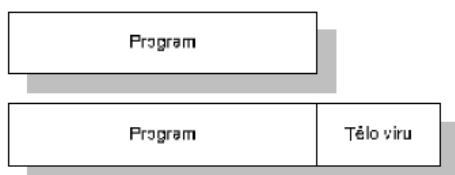
V případě EXE souboru je situace komplikovanější. Během infekce musí dojít ke změně některých hodnot hlavičky (původní jsou opět uloženy na určité místo těla viru – nejčastěji CS, IP, SS, SP nebo rovnou celá hlavička) a ostatní musí být dopočítány. Žádná instrukce skoku se nekládá, na začátek kódu viru ukazuje přímo tzv. entry-point (vstupní bod), tedy hodnoty CS:IP hlavičky. Hrátky s hlavičkou a s původním obsahem souboru lze různě kombinovat, proto mohou vzniknout následující metody infekce¹².

Prepend – Virus se nachází před původním programem. Původní program může být odsunut celý vzad, popřípadě přesunuta pouze úvodní část, místo které je umístěno tělo viru.



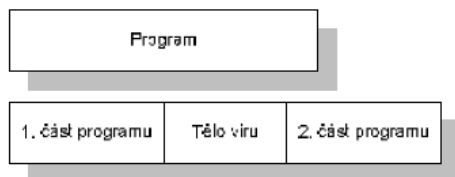
Obrázek - Metoda infekce – prepend.

Append – nepoužívanější metoda. Obecně ji odpovídá i schéma při infekci COM a EXE souborů.



Obrázek - metoda infekce – append.

Insert – málo využívaná metoda. Při využití této metody se nabízí více možností, jak vynaložit s hodnotou ukazující na začátek původního programu (entry-point). Virus ji nemusí měnit, pokud se vloží přesně na místo, kde původní program začínal. V opačném případě ji měnit musí. Jistou alternativou jsou tzv. „mezerové“ viry (cavity viruses), které jsou ale spíše záležitostí Win32 virů. Při této metodě dochází k přepsání „prázdných“ míst souboru a tak nedojde ke změně velikosti souboru po infekci. ¹² Jde pouze o znázornění vzájemného umístění těla viru a původního programu.



Obrázek - metoda infekce – insert.

Schéma činnosti souborových virů

Viry přímé akce – přepisující

Virus je aktivován v okamžiku, kdy je spuštěn libovolný infikovaný program, a jeho první starostí je vyhledat jiný vhodný program, který je možno napadnout. Virus zkopíruje své tělo na začátek vyhlednutého programu, čímž si zajistí, že bude aktivován okamžitě po jeho spuštění, ale zároveň je tímto krokem cílový program nenávratně zničen.

Pokud jsou splněny zadané podmínky, virus vykoná své poslání. Virus nemůže pokračovat v činnosti původního programu, proto jej bezprostředně ukončí, často s nějakým hlášením naoko vysvětlujícím nemožnost běhu programu (například fiktivní nedostatek paměti).

Viry přímé akce – parazitické

Tento krok je naprosto shodný jako v předchozím případě. Virus připojí vlastní kód k programu tak, aby zachoval všechny informace potřebné k jeho správné činnosti. Nejjednodušším způsobem jak to zařídit, je připojit tělo viru za konec napadeného programu. Aby však byl virus aktivován okamžitě po spuštění infikovaného programu, musí na začátek programu vložit instrukci skoku na tělo viru (případ COM souboru), přičemž původní kód, který je přepsán skokovou instrukcí, je uložen do těla viru.

Viry paměťově rezidentní – parazitické

Při spuštění napadeného programu virus zjistí, není-li již rezidentní v paměti. Pokud nalezne svou kopii v paměti, pokračuje posledním bodem.

V opačném případě vyhledá a vyhradí pro své použití (tzv. alokuje) úsek paměti vhodné velikosti.

Překopíruje sám sebe do tohoto úseku paměti a změní adresy některých diskových (a případně i jiných) služeb tak, aby směřovaly do těla.

Obnoví začátek napadeného programu (pouze v paměti, ne na disku) a tento program spustí.

Pokud je od této chvíle spouštěn jakýkoli program, je nejdříve vyvolán rezidentní virus, který tento program infikuje tím, že připojí svůj kód ke kódu programu a změní úvodní skok (stejně jako u parazitických virů přímé akce), popřípadě hlavičku (případ EXE souboru).

Paměťová ne/rezidentnost

Základní dělení

Nerezidentní viry - viry přímé akce

Tyto viry nevyužívají paměť pro své šíření. Stačí jim, když jsou aktivovány společně s hostitelským programem. Pak přebírají řízení jako první, provedou svoji činnost, nejčastěji replikaci a předají řízení zpět hostitelskému programu. Replikací zde většinou rozumíme například napadení všech vhodných souborů (postupně nebo naráz) v aktuálním adresáři, či napadení souborů uvedených v proměnné DOS PATH.

Paměťově rezidentní viry

Paměťově rezidentní virus setrvává ilegálně v paměti. Takový virus se většinou při prvním spuštění infikovaného souboru (pokud se jedná o souborový virus) nebo při prvním zavedení systému z infikovaného boot sektoru (pokud se jedná o boot virus) stane rezidentním v paměti, a odtud potom provádí svoji škodlivou činnost. Virus zůstává v paměti dokud není systém vypnut. Naprostá většina virů pro operační systém MS-DOS se umísťuje až na vrchol systémové paměti, ale pod mez 640 KB. Existují však i viry, které využívají nízkou systémovou paměť, paměť videokarty atd. pro ukrytí kusu svého kódu. Se zapnutím systému jsou okamžitě schopny infekce souborů či boot sektoru nebo tabulky rozdělení. Boot viry jsou už z principu paměťově rezidentní. Paměťově rezidentním virům se věnují i následující kapitoly.

Makroviry

První z nich se objevil v roce **1995** a jmenoval se WM/Concept.A. Jak naznačuje samotný název skupiny, jsou tvořeny makry. Již první kancelářské aplikace umožňovaly práci s takzvanými makry. Tehdy se ve většině případů jednalo o zapamatování a uložení posloupnosti kláves (klávesnicová makra). Tato makra mohla být opakovaně vyvolána a mohla zjednodušit a zautomatizovat práci aplikačního programu. Postupem se ale způsob práce s makry měnil, takže dnes jsou makra vytvářena ve speciálních vyšších programovacích jazycích, jejichž možnosti se vůbec neliší od klasických programovacích jazyků. Mohou tedy manipulovat s daty aplikace a také s makry, které jsou s danými daty spojeny (například je kopírovat). Bohužel mohou i modifikovat ostatní data na daném počítači.

Makro (nebo souhrn maker), které je schopno zkopírovat sebe sama z jednoho dokumentu do druhého (a to opakovaně), je nazýváno makrovirem. Je zřejmé, že úspěšné šíření viru vyžaduje několik podmínek. Používaná aplikace musí být široce používána a musí docházet k výměně dat včetně maker mezi jednotlivými uživateli a počítači. Všechny tyto podmínky dnes splňují hlavně programy **Microsoft Word a Microsoft Excel**, a proto jsou zdaleka nejrozšířenější právě makroviry pro tyto dva programy (součástí kancelářského balíku Microsoft Office).

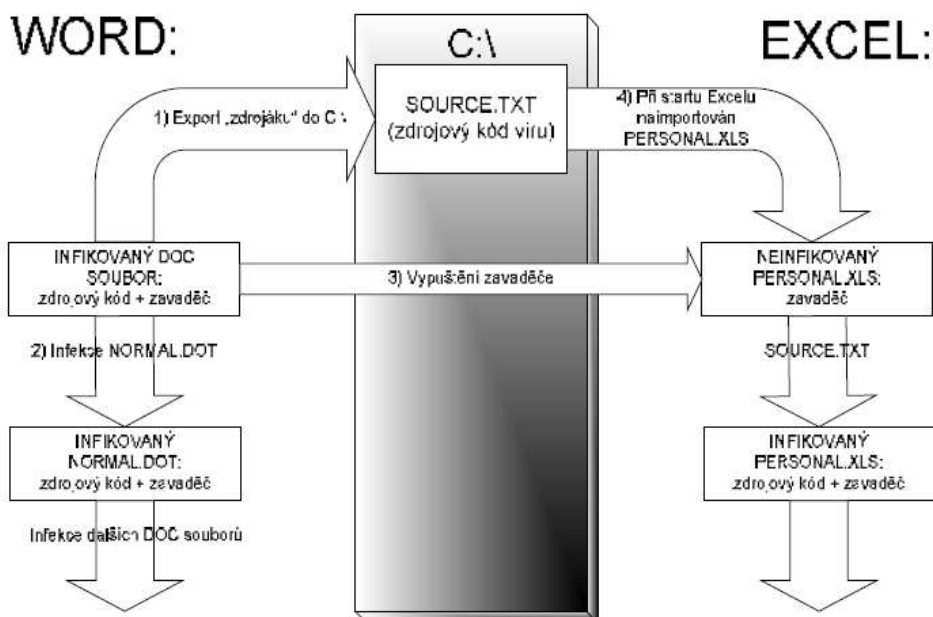
Programy z MS Office neukládají makra, spjatá s dokumentem, do zvláštního souboru, ale do stejného, ve kterém jsou uložena vlastní data. V takovém případě se tedy nejedná o čistě datové soubory, ale svým způsobem o programy. To zásadně mění přístup k takovým souborům z hlediska bezpečnosti.

Pro ukládání údajů do souboru používá Microsoft svůj vlastní formát, nazývaný Compound Storage File, který je součástí OLE2 (Object Linking and Embedding). Takový soubor obsahuje svůj vlastní souborový systém, včetně tabulek FAT, adresářů, podadresářů, souborů. Struktura souboru (a způsob uložení maker) nebyla firmou Microsoft nikdy zveřejněna, je definováno pouze API rozhraní, které však v řadě případů nechtějí či nemohou antivirové programy využívat, a to někdy z principiálních důvodů (například pro programy pracující pod MS-DOSem není API k dispozici). Způsob uložení maker se navíc mezi jednotlivými verzemi značně liší.

Zajímavou vlastností makrovirů je to, že mohou fungovat jak na různých počítačích (IBM PC, Macintosh) a tedy i operačních systémech (Windows 3.1, Windows 9x, Windows NT, MacOS), tak i na různých aplikacích v rámci kancelářského balíku (nejčastěji MS Office). Příkladem může být makrovirus O97M/Tristate, který je schopen napadat dokumenty všech tří základních aplikací MS Office (Word, Excel, Powerpoint) – tzv. cross-infektor.

Pokud hovoříme o fungování pod různými operačními systémy, pak lze do této kategorie zařadit teoreticky všechny makroviry využívající kancelářského balíku MS Office. Důvod je prostý, MS Office neexistuje pouze pro MS Windows, ale i pro MacOS a makroviry lze považovat za multi-platformní.

¹³ Jisté potíže mohou nastat při využití externích objektů mimo aplikaci Microsoft Office. Příkladem může být využití jistého externího programu, který je součástí platformy Windows, nikoliv MacOS.



Obrázek - princip fungování cross-infektorů, kdy je exportován zdrojový kód makroviru do speciálního souboru (v uvedeném případě SOURCE.TXT) a následně pak importován do dalších aplikací balíku Microsoft Office.

Protože největší reálnou hrozbu představují makroviry aplikace MS Word, budou se následující části věnovat nejvíce právě ji. Jaký je tedy princip činnosti makroviru? Pro Word funguje většina makrovirů následujícím způsobem: makrovirus je uložen v napadeném dokumentu. Pokud je takový dokument otevřen a načten danou aplikací, může být za určitých podmínek virus spuštěn (např. pomocí automaker, ale i jinými způsoby, o nichž se zmíníme za chvíli). Virus pak může zkopírovat sebe sama do nějakého globálního dokumentu, který mu zajistí aktivaci při každém následujícím spuštění aplikačního programu (u Word je to soubor NORMAL.DOT). Při dalších spuštěních aplikace tak zůstává aktivní a může napadat všechny vytvářené, modifikované či jen čtené dokumenty. Toto samozřejmě není jediná cesta, jak se mohou makroviry šířit, je však rozhodně nejpoužívanější.

Dokumenty & Šablony

Word rozlišuje dva typy dokumentů, se kterými pracuje. Dokumenty a šablony. Počínaje Wordem 97 (8.0) došlo k radikálním změnám ve struktuře dokumentů a implementaci makrojazyka VBA 5 (Visual Basic for Applications). Do doby Wordu 95 (7.0) tak platilo následující. Šablony mohly kromě klasických dat obsahovat různé další informace, jako definice tlačítek lišty, klávesové zkratky, či právě makra. Rozlišení mezi oběma typy nebylo dáno rozšířením ve jméně souborů (.DOC pro dokumenty a .DOT pro šablony), i když tato rozšíření Word standardně používá. Vlastní rozlišení bylo v jediném bitu ve stavovém slově uvnitř dokumentu. Typ dokument nemohl uživatel změnit pomocí prostředků Word, výjimkou byl příkaz makrojazyka, který byl makroviry používán. Soubory, označené jako dokumenty, mohly obsahovat makrovirus, který byl ale v tom případě v neaktivním stavu. Dokumenty, které makrovirus napadl, byly vždy změněny na šablony, aby virus mohl být při jejich načtení aktivován.

Automakra

Vlastností Wordu i dalších aplikací v rámci Office firmy Microsoft, která zcela jistě přispívá k šíření makrovirů, jsou automakra. Jedná se o makra se speciálními jmény, která jsou za určitých podmínek automaticky vykonána. Příkladem mohou být makra AutoExec (automaticky spuštěno při startu programu), **AutoOpen** (při otevření dokumentu), AutoClose (při uzavření dokumentu) a AutoExit (při skončení aplikace). Naneštěstí provedení těchto maker nejde jednoduše a spolehlivě zakázat, navíc mají přednost makra, uložená v právě otevíraném dokumentu před globálními makry (např. z NORMAL.DOT).

Změny v menu

To však zdaleka není jediný způsob, jakým může být makrovirus aktivován. Ve skutečnosti je celé prostředí dnešních aplikací velmi flexibilní - pomocí maker je možno předefinovat libovolnou položku menu či libovolné tlačítko na stavové liště. Makrovirus pak může být aktivován například tím, že uživatel uloží nebo vytiskne

soubor. Tuto vlastnost řada virů využívá i pro skrývání své přítomnosti, když manipuluje s položkou Nástroje / Makro. Existují viry, které takovou položku prostě zakáží, změni ji na prázdné okno, simulují chybu či dokonce zobrazí všechna makra, samozřejmě kromě svých. Uživatel může jen těžko zjistit prostředky dané aplikace přítomnost viru.

Předdefinované klávesy

Další věcí, kterou jsou schopna makra modifikovat, jsou klávesové zkratky a vůbec stisk libovolné klávesy. Virus tak může být aktivován, kdykoli například stisknete klávesu „a“, „e“ nebo mezerník (virus WM/Gangsterz.A).

Skriptové viry

Pokud vynecháme primitivní pokusy škodlivých skriptů v podobě dávkových souborů (.BAT), které mohou překvapit pouze občasným primitivním kódováním, zůstávají reálnou hrozbou pouze, **VBS** a **JS** skripty.¹⁵ Možnosti dávkových souborů BAT nebyly natolik široké, aby uspokojily některé uživatele operačního systému Windows a tak příchod Internet Exploreru 5.0 znamenal i příchod modulu Windows Script Host. Modul Windows Script Host (nachází se v souboru **WSCRIPT.EXE**) umožňuje vykonávat VBScript (Visual Basic Scripts) a JScript (Java Scripts) a to podobně jednoduše jako v případě klasických spustitelných souborů, tj. pouhým poklepnutím myši na příslušnou ikonu apod. Bohužel s příchodem Windows Script Host nastal shodný problém jako v případě makrovirů. Skriptovací jazyk (Visual Basic) nabízí takové možnosti, že není problémem vytvořit úspěšně se šířící virus, nejčastěji prostřednictvím elektronické pošty. Navíc můžou být výše uvedené skripty vloženy přímo do HTML kódu stránek a při nevhodném nastavení Internetového prohlížeče může dojít k jejich samovolné aktivaci. Hrozbou mohou být i soubory s příponou SHS. V tomto případě jde o jakousi OLE „obálku“, která VBS či JS skript může obsahovat. Bohužel „nevhodné“ nastavení je v řadě případů zároven i standardním nastavením (především Internet Explorer). Příkladem může být následující skript, který ve spojení s některými verzemi Internet Exploreru dokáže neuvěřitelné věci.

```
<HTML>
<BODY>
<SCRIPT language=VBScript>
<!--
MsgBox "Click here to recieve a free cup holder",64,"Your free Cup holder"
Set oWMP = CreateObject("WMPlayer.OCX.7" )
Set colCDROMs = oWMP.cdromCollection
if colCDROMs.Count >= 1 then
For i = 0 to colCDROMs.Count - 1
colCDROMs.Item(i).Eject
Next ' cdrom
End If
-->
</SCRIPT>
</BODY>
</HTML>
```

Samostatnou kapitolou je ActiveX controls, kde opět rozhoduje nastavení Internet Exploreru a dále označení ActiveX controls „safe for scripting“ („bezpečný pro provedení“). V minulosti totiž byla objevena bezpečnostní chyba v podobě nesprávného označení dvou ActiveX controls jako „safe of scripting“: Scriptlet.typelib a Eyedog i když mohly být zneužity pro šíření virů, což se potvrdilo vznikem viru VBS/Bubbleboy. CreateObject(“Scriptlet.TypeLib”) Výše uvedený řádek (a několik dalších) mu umožnilo vytváření souborů na PC oběti bez jeho svolení. Bezpečností záplata se objevila v bulletinu Microsoftu MS99-032. Zřejmě nejznámějších skriptů virem je VBS/Loveletter.A („I love you“).

Souborové viry pod Win32

Viry (či dnes spíše trojské koně) pro Win32, tj. pro Windows 9x / Me / NT (2000, XP atd.) jsou nejčastější dnešní formou infiltrace. Funkčnost Win32 virů zajišťuje Win32 API, (Application Program Interface) tedy množina funkcí operačního systému Windows 9x a NT (včetně 2000, 2003, XP). Prvně se Win32 API objevilo v operačním systému Windows NT a v omezeném rozsahu i ve Windows řady 9x. To je zároveň i jeden z důvodů,

proč jsou některé Win32 viry nekompatibilní mezi řadou Windows 9x a NT. Nová éra 32-bitových Windows přinesla i nový spustitelný formát souborů – Portable Executable (PE).

Zjišťování vstupních adres funkcí API

I když by na první pohled mohlo jít o jednoduchou činnost a aplikace či dokonce virus by si prostě po potřebné API funkci „sáhly“ na určitou, přesně danou adresu, ve skutečnosti je situace daleko komplikovanější. Umístění jednotlivých funkcí v paměti a tím i hodnoty vstupních adres pro každou funkci se totiž liší s každou novou verzí operačního systému Windows a to dokonce i v rámci jedné „řady“ (například starší Windows 95 a Windows 95 SR2).

Poštovní viry v binárních souborech (PE)

Nejčastější formou je prvně jmenovaná skupina, tedy viry šířící se poštou ve formě PE EXE souborů. Zde je nutno poznamenat, že formát souboru (tj. jeho vnitřní struktura), nemusí odpovídat použité příponě souboru. Díky této skutečnosti se mohou šířit nejen přímo infikované soubory s příponou **EXE**, **ale i SCR, PIF** atd. Častým jevem je využití tzv. dvojité přípony (např. soubor.jpg.exe), jelikož při určité konfiguraci systému je zobrazena pouze první z nich a případná oběť tak může propadnout mylné představě, že jde o neškodný soubor (v našem případě JPG, tedy grafický soubor). Mylnou představu může podpořit i interní ikona infikovaného PE souboru. V řadě případů nejde o klasické parazitické viry, tj. souborové viry, které by infikovaly další soubory na pevném disku. Při spuštění infikovaného souboru v příloze emailu tak nejčastěji dochází pouze k vypuštění několika souborů do operačního systému, které se starají o budoucí replikaci prostřednictvím elektronické pošty. Obvykle je nutno zajistit jejich automatickou aktivaci po každém startu PC a jako nejvhodnější metodou se jeví klíč HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run v registrech Windows. Alternativou je i soubor WIN.INI a řádek RUN=, ale ten je využíván pro jiné, níže uvedené účely. Další činnost závisí na „inteligenci“ daného viru. Jeho úspěch může být odvozen například od toho, zda bude testovat aktuální stav připojení k Internetu. Využít může například API funkci InternetGetConnectedState z WININET.DLL či využít vhodné API funkce z WINSOCK.DLL (jen Windows řady 9x). Další průběh můžeme zhodnotit v následujících podkapitolách.

Získávání e-mailových adres budoucích obětí

Agresivita viru, s jakou se pustí do získávání dalších e-mailových adres, na které pak hromadně rozešle svoji kopii, může hodně napovědět o případném úspěchu daného viru. V dnešní době jsou známy následující tři základní metody získávání (harvesting) emailových adres.

Prohledávání vhodných souborů

Jednou z cest, jak získat dostatek e-mailových adres je průzkum HTML souborů na pevném disku. Viry mají v oblibě především adresář Internet Temporary Files, kam Internet Explorer průběžně ukládá stažená data. Jednoduchým algoritmem na vyhledávání řetězců označujících e-mailovou adresu (řetězec „mailto:“) jich lze najít velké množství. Některé viry prohlížejí soubory s více než dvaceti různými příponami.

Prohledávání WAB (Windows Address Book)

Soubor s příponou WAB obsahuje všechny e-mailové adresy, které si uživatel vede v adresáři aplikace MS Outlook Express. Vlastností novějších verzí Outlooku je, že do knihy adres jsou automaticky přidávány i e-mailové adresy, na které jsme někdy v minulosti odpovíděli. WAB tak může být velice rozsáhlý co do počtu e-mailových adres.

Prohledávání samotných složek pošty

Výsledkem poslední metody je v řadě případů zisk velice „blízkých“ e-mailových adres z pohledu uživatele, u něhož virus průzkum způsobil. Průzkumem složek jako „Doručená pošta“ (INBOX) lze najít velké procento adres, které patří blízkým přátelům. Viry zaslané od blízkých přátel a maskované dokonalým textem mohou působit velice „psychologicky“²¹.

Pevně definované SMTP servery (hard-coded)

Tuto metodu uplatňuje minimum dnešních virů šířících se elektronickou poštou. Důvodů je několik. Pevně definované SMTP servery (nejčastěji prostřednictvím IP adresy) nemusí být dostupné během celé aktivní působnosti viru. Dostupnost SMTP serverů k odesílání e-mailů z vnější sítě (z Internetu, tzv. open relay) je ve

většině případů důsledkem nevhodné konfigurace SMTP serveru. Při případném upozornění majitele takového SMTP serveru ze strany antivirových společností, může dojít k nápravě a tím i k zastavení šíření viru. Ve světě existuje veřejná databáze „Open Relay Database“ (www.ordb.org), která ve svých záznamech udržuje právě open relay SMTP servery, tj. servery, které lze libovolně zneužít pro odesílání e-mailů odkudkoliv kamkoliv. Pokud se případný virus bude šířit právě prostřednictvím takového serveru, může dojít k situaci, kdy cílový SMTP server e-mail odmítne s tím, že byl odeslán z open relay serveru.

Uživatelé používaný SMTP server

Tato metoda vychází z využití MAPI rozhraní e-mailového klienta Microsoft Outlook, popřípadě s úpravou či vypuštěním vlastního souboru WSOCK32.DLL, za pomoci něhož může virus monitorovat Internetové připojení. V případě zmiňované knihovny mohou být pro virus zajímavé například následující API funkce: send, recv, connect.

Vlastní SMTP server

Daleko populárnější je vlastní jednoduchý SMTP server na portu 25, který si virus po případné aktivaci vypustí do operačního systému.

Konání dalších činností

Výčet činností by mohl být velice široký a značně se prolíná s kapitolou „Techniky virů šířících se elektronickou poštou“.

Poštovní skriptové a makroviry

Éra skriptových virů a makrovirů pravděpodobně skončila, ale i tak je vhodné se o nich zmínit. Zatímco makroviry šířící se elektronickou poštou tvoří vždycky soubor v příloze (s příponou DOC, XLS apod.)²³, u skriptových virů již není situace natolik jednoznačná. Malá skupina skriptových virů je totiž přímo součástí zprávy. K tomu by nemohlo nikdy dojít v případě, že by e-mail zůstal ke svému původnímu účelu, tj. 22 Často jsou zneužívány pro rozesílání SPAMu. 23 Obvykle tak jde přímo o odcizený dokument. k zaslání textových zpráv elektronickou cestou. Nové trendy ovšem působnost značně rozšířily, takže kromě textových zpráv může jít i o multimediální skvosty plné blikajících písmenek, obrázků a hudebních efektů. Z pohledu virů je v tomto směru největším přínosem implementace jazyka HTML přímo do poštovních klientů (především Microsoft Outlook / Express). HTML jazyk a tedy i e-mail může obsahovat vnořené skripty (například VBS, JS), čehož mohou viry využít a šířit se ve formě těchto skriptů (VBS/Bubbleboy, WScript/Kakworm). Alternativou mohou být skriptové viry, které hlavní část vlastního těla soustředí na určitém místě sítě Internet. Při případné aktivaci skriptu si lze HTML tagem IFRAME tuto část vyžádat (viz. www.w3.org). Jelikož skriptové jazyky nenabízejí takové možnosti jako v případě assembleru a souvisejících „binárních“ virů, jsou skriptové viry a makroviry jednodušší a čitelnější formy. V řadě případů jsou tak odkázány na MAPI rozhraní poštovních klientů a zároveň tak schopny replikace pouze pod plnohodnotným MS Outlookem a nikoliv Expressem. Proto i následující kapitola se této skupiny virů týká okrajově.

Techniky virů šířících se elektronickou poštou

Maskovací techniky

Dvojitá přípona

Jedná se často využívanou metodu. Infikovaný soubor v příloze e-mailu má dvojitou příponu, tj. název.př1.př2. Na některých konfiguracích Windows se výše uvedený příklad jeví pouze jako název.př1, přičemž skutečná přípona, ze které operační systém vychází (čte název souborů zprava) zůstává vizuálně utajena. Výsledkem může být mylná představa uživatele, že jde o zcela neškodný soubor a co víc, že jde o více než zajímavý soubor. Reálným příkladem může být úspěšný virus VBS/SST.A, který se šířil v souboru AnnaKournikova.jpg.vbs. Pokud se uživateli zobrazilo jen AnnaKournikova.jpg, jen těžko by někdo odolal pohledu na obrázek krásné ruské tenistky. Idylka skončila ve chvíli, kdy se místo obrázku tenistky spustil škodlivý VBS skript s cílem rozeslat tento „obrázek“ do dalších koutů světa.

„Bílé“ znaky

Jde o alternativu k dvojitému příponám. Pokud by šlo o konfiguraci systému, zobrazující obě přípony, je jistou šancí za konec první z nich vložit velké množství mezer a tak onu druhou posunout za vizuálně viditelnou oblast.

Falšování skutečného odesílatele (spoofing)

Většina dnešních virů šířících se elektronickou poštou využívá e-mail spoofingu, tedy falšování adresy skutečného odesílatele. Na místo adresy skutečného odesílatele bývá dosazena zcela odlišná adresa, ať už fixní (virus Win32/Sobig.B dosazoval adresu support@microsoft.com) či proměnlivá (prohlídkou knihy adres apod.). Nepříjemným efektem mohou být rozhořčené dopisy uživatelů, rozesílané na nesprávnou adresu odesílatele. Více viditelným problémem jsou ovšem automatické odpovědi některých antivirových systémů na poštovních serverech. Ty se snaží e-mailovou odpovědí upozornit dotyčnou osobu na skutečnost, že na hlídaný server zaslala virus. Bohužel tím, že je adresa skutečného odesílatele podvržena, dostane toto upozornění zcela nevinný uživatel. Pokud jde zároveň o nezkušeného uživatele, může celá situace dojít tak daleko, že přestane věřit vlastnímu antivirovému systému a celý svůj operační systém kompletně přeinstaluje jen na základě těchto falešných zpráv. Skutečného odesílatele je možno vypátrat jen na základě údajů v hlavičce emailu, a to konkrétně u položky „Received:“. Záleží zcela na poštovním serveru, jak podrobné informace do této části e-mailu zapíše.

Nejobecnější techniky infiltrace

Stealth

Pod tajemně znějícím pojmem „stealth“ se skrývá celá skupina prostředků, určených k zamaskování přítomnosti viru. Princip spočívá v tom, že virus kontroluje nejrůznější aktivity počítače a v případě potřeby falšuje některé údaje nebo modifikuje některé činnosti. Sledování aktivit je realizováno opět pomocí přesměrování služeb (vektorů přerušení, API funkcí) na virus. Podle toho, které služby je virus schopen zpracovávat a falšovat jejich výsledky, lze rozlišovat úroveň stealth techniky. Za nejjednodušší formu (semi-stealth) je považováno **uvádění falešné délky souborů**. Přesměrováním vhodné služby operačního systému lze docílit, že soubory se budou ve výpisu (ať už příkazem DIR, v souborovém manažeru, v průzkumníku) jevit v původní délce před infekcí. Vyspělejší viry jsou komplexnější, takže k maskování dochází i při prohlížení infikovaného souboru v nějakém editoru, kdy je zobrazen pouze původní nezávadný kód. K této efektivní činnosti může docházet při vhodném přesměrování služeb operačního systému, týkajících se otevření souboru (otevření souboru v editoru - rychlá dezinfekce) a uzavření souboru (ukončení práce se souborem - opětovná infekce). I když byl v případě operačního systému MSDOS prvním stealth virem paradoxně hned ten nejstarší – Brain z roku 1986, v případě Win32 virů jsme se takové události hned tak nedočkali. S příchodem Win32 jako by stealth viry zcela vymřely a najít některý rozšířený Win32 virus s výše uvedenou technikou je skoro nemožné. Avšak i vývoj pod Win32 systémy pokračuje a tak se objevuje relativně nový pojem (alespoň pod systémy Microsoft) – rootkit.

Rootkity

Rootkit je pojem, který se s operačním systémem Windows společnosti Microsoft objevil až nedávno. Původně jde o pojem z UNIXového světa, kde byly tímto pojmem označovány programy, které umožnily hackerovi zakrýt nekalou činnost, kterou prováděl. Za tímto účelem byly některé systémové programy (login, ls...) a systémové knihovny (typicky libproc.a) nahrazeny, popř. bylo využito možností modulů kernelu. Zpět však k Windows. V současnosti lze pod MS Windows najít dvě hlavní skupiny rootkitů, které využívají k maskování:

- modifikaci cest,
- modifikaci systémových struktur.

Tyto metody slouží především k **maskování změn v registrech, v procesech, popř. k maskování zvýšené síťové aktivity**. Odlišné může být například dělení podle vrstvy systému, na které rootkit pracuje: tzv. user mode nebo kernel mode. Typickou ukázkou „modifikace cest“ může být „podchycení“ (přesměrování, hooking apod.) některých důležitých API funkcí operačního systému (viz. teorie fungování virů na začátku této publikace a informace o „import / export table“), kdy rootkit „sedí“ mezi aplikací uživatele a DLL knihovnou, která danou API funkci obsahuje. Oproti tomu druhá metoda je specialitou „kernel mode“ rootkitů. Tyto aplikace obvykle modifikují často ne příliš dokumentované systémové struktury (okolo čehož se motají pojmy jako

KeServiceDescriptorTable, PsActiveProcessList). Toto může nakonec vést například k tomu, že rootkit dokáže zcela zakrýt libovolný proces před jiným softwarem.

Kódování & Polymorfismus

Souborové viry

Prvotním účelem kódování bylo zneprůhlednit vlastní kód viru a ztížit tak jeho analýzu. Navíc je tímto postupem zkomplikováno uzdravení napadeného programu, protože původní obsah začátku souboru (hlavičky) je také zakódován. Takové kódování realizovaly některé souborové viry tak, že vlastní kód viru byl v programu uložen – zakódován nějakým jednoduchým algoritmem (oblíbené bylo provedení operace XOR s každým bajtem kódu viru) a před vlastním virem se nachází krátká dekryptovací smyčka, která zajistí jeho transformaci do původní podoby (některé viry tuto smyčku rozdělují na několik navzájem propojených částí po souboru). Takto zakódovaný virus má téměř konstantní podobu. Téměř proto, že stejně jako běžné viry si potřebuje do svého těla zapsat několik proměnných hodnot, které mohou být v každé generaci odlišné; převážná část viru zůstává neměnná. Novější viry začaly využívat kódování s proměnlivou hodnotou k dosažení toho, aby každý exemplář viru byl z velké části odlišný; shodná zůstává pouze dekódovací smyčka na začátku programu. To sice značně zkomplikovalo vyhledávání některým antivirovým programům používajícím charakteristické sekvence, ale neustále bylo relativně snadné určit kódovací hodnoty a program dekódovat. Navíc šlo stále použít vždy stejně vypadající dekódovací smyčku k identifikaci viru. Nástupce této technologie představují polymorfní viry, které používají poměrně komplikovaných metod k tomu, aby i **dekódovací smyčka mohla mít proměnlivou podobu.** U takového viru se liší každý jednotlivý exemplář a proto je nemožné použít k jeho vyhledávání charakteristické sekvence. Jednodušší viry používají k dosažení různorodosti metodu prokládání nevýznamnými instrukcemi a záměny pořadí, v případě DOS souborového viru například jednoduchá smyčka typu:

```
MOV BX, zacatek_viru ; adresa první zakodované instrukce
```

znovu:

```
XOR [BX], AL ; kódovací funkce
```

```
INC AL ; zmen kódovací konstantu
```

```
INC BX ; prejdi na další bajt
```

```
CMP BX, konec_viru ; test na konec viru
```

```
JNE znovu ; pokud není celé tělo rozkodováno,
```

```
opakuj
```

může být v příští generaci viru bez změny funkčnosti realizováno takto:

```
MOV BX, zacatek_viru
```

```
NOP ; nevýznamná instrukce
```

znovu:

```
XOR [BX], 13h
```

```
CLC ; změna příznaku CY nic neovlivní
```

```
INC BX ; prohozené pořadí těchto dvou instrukcí
```

```
INC AL ; nemá žádný vliv na činnost
```

```
CMP BX, konec_viru
```

```
NOP ; nevýznamná instrukce
```

```
NOP ; nevýznamná instrukce
```

```
JNE znovu
```

Takové změny později dokázaly všechny antivirové programy podchytit, proto autoři virů tyto metody dále zdokonalovali. Jednou ze skutečností, která je využívána k těmto účelům je fakt, že díky ne zcela dokonalému instrukčnímu souboru použitých procesorů Intel lze stejnou instrukci zapsat různým způsobem:

; operacní kód instrukce

```
93 HG AX,BX ; instrukce výměny obsahu
```

; registru AX a BX

```
87 C3 XCHG AX,BX ; což má naprosto stejný
```

```
87 D8 XCHG BX,AX ; efekt jako předchozí
```

Postupem času se začaly objevovat viry, které každou svoji kopii kódují odlišným algoritmem a používají stále komplikovanější programové konstrukce uvnitř dekódovacích smyček.

Příchod operačního systému Windows 9x/NT s sebou přinesl další prostor pro rozvoj těchto virů. Některé obsahují dekryptovací smyčku hned v několika vrstvách, jiné pak aplikují „brute force attack“ náhodně

generovanými klíči k dekryptování (Win32/Crypto českého autora Prizzy). K tomuto musí dojít, jelikož virus úmyslně „ztratí“ klíč potřebný k dekryptování těla viru. Při spuštění infikovaného souboru je tento klíč hledán metodou „pokus/omyl“ (tedy „brute force attack“), takže než dojde k vykonání samotného těla viru, může uplynout i polovina sekundy (záleží na rychlosti CPU). Úmyslem je ztížení prostupnosti kódu případným emulátorem. Nástupci jsou metamorfní viry.

Makroviry

Podobný vývoj potkal i makroviry. K jisté úrovni polymorfismu může makrovirus dojít několika způsoby. Příkladem může být **náhodné prohazování řádků kódu**, které jsou ve správném pořadí volány skoky (goto).

```
GoTo 10
```

```
70 NI = NormalTemplate.VBProject.VBComponents(1).CodeModule.Lines(2, 1):
```

```
GoTo 80
```

```
110 If NormInstalled = True And ActInstalled = True Then Exit Sub Else:
```

```
GoTo 120
```

```
140 With Carrier: VirCode = .Lines(1, .CountOfLines): End With: GoTo 150
```

```
10 Application.EnableCancelKey = wdCancelDisabled: GoTo 20
```

Jiným příkladem může být prokládání kódu poznámkami (rem).

```
Sub AutoOpen()
```

```
'12607257448915407195041260725744891540719504126072574489154071950412607257
```

```
44891540719504
```

```
Randomize
```

```
'93613357369444222593613357369444222593613357369444222593613357369444222
```

```
25
```

```
x = 0: o = 0
```

```
'10583180112420650839616105831801124206508396161058318011242065083961610583
```

```
180112420650839616
```

```
On Error GoTo 93
```

V neposlední řadě pak proměnlivost názvů proměnných, procedur a funkcí.

```
If j68657670 = vbReadOnly And System.OperatingSystem = "Windows" And
```

```
System.LanguageDesignation = "English(United States)" Then Call
```

```
XRoach(f9517$)
```

```
If j68657670 = vbReadOnly + vbArchive And System.OperatingSystem =
```

```
"Windows" And System.LanguageDesignation = "English(United States)" Then
```

```
Call XRoach(f9517$)
```

```
If j68657670 = vbReadOnly Then GoTo dRoach
```

```
If j68657670 = vbReadOnly + vbArchive Then GoTo dRoach
```

```
For I = 1 To ActiveDocument.VBProject.VBComponents.Count
```

```
If ActiveDocument.VBProject.VBComponents(I).Name = "Roach" Then
```

```
tcd7670485512 = True
```

Metamorfismus

Narozdíl od polymorfních dochází u metamorfních virů ke **změnám v samotném zdrojovém kódu viru** (v případech polymorfních virů byl zdrojový kód a tím i samotné tělo neměnné, i když navenek pokaždé jinak zakryptováno) i když ke změnám jeho působnosti nedochází.

Pravděpodobně prvním a zároveň úspěšným virem tohoto druhu byl slovenský TMC:Level_6x9.A (TMC – Tiny Mutation Engine) autora Ender. V infikovaném souboru se nenachází tělo viru v klasické binární podobě, ale jen kompilátor, společně se zdrojovým pseudo-kódem viru. Při spuštění infikovaného souboru kompilátor sestaví do paměti novou, vzhledově zcela odlišnou kopii viru. Kompilátor neobsahuje žádné podezřívavé instrukce a není ho proto možno běžně detekovat heuristicky. Během kompilace se mezi jednotlivé instrukce mohou, ale nemusí vkládat instrukce skoku. Délka skoku není předem známa, proto se musí vyhradit pro každý skok více místa, než je potřeba. Důsledkem je poměrně častý výskyt třech instrukcí NOP následujících po sobě. Trochu odlišně přistupoval k situaci již 32-bitový virus Win32/Apparition. Ten kompilátor nenesl v infikovaném souboru s sebou, nýbrž si ho drze dovolil hledat na uživatelském disku a rovněž ho využít. Virus Win32/Regswap modifikoval vlastní kód výměnou používaných registrů. V následující ukázce je to viditelné.

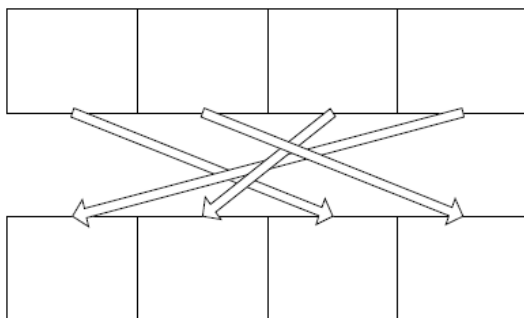
Následující ukázky jsou z článku „Hunting for metamorphic“ - Péter Szor a Peter Ferrie – Symantec Corp.

```

BF04000000 mov edi,0004h
8BF5 mov esi,ebp
B80C000000 mov eax,000Ch
81C288000000 add edx,0088h
8B1A mov ebx,[edx]
899C8618110000 mov [esi+eax*4+00001118],ebx
58 pop eax
BB04000000 mov ebx,0004h
8BD5 mov edx,ebp
BF0C000000 mov edi,000Ch
81C088000000 add eax,0088h
8B30 mov esi,[eax]
89B4BA18110000 mov [edx+edi*4+00001118],esi

```

Jak je z ukázky patrné, je stále možno využít detekci na bázi sekvencí. Některé další Win32 viry se pokoušely o přehazování vlastních podprogramů (procedur a funkcí), čímž mohlo vzniknout teoreticky až $n!$ kombinací, jestliže n značí množství takových podprogramů.



Obrázek - ilustrační schéma přehození podprogramů.

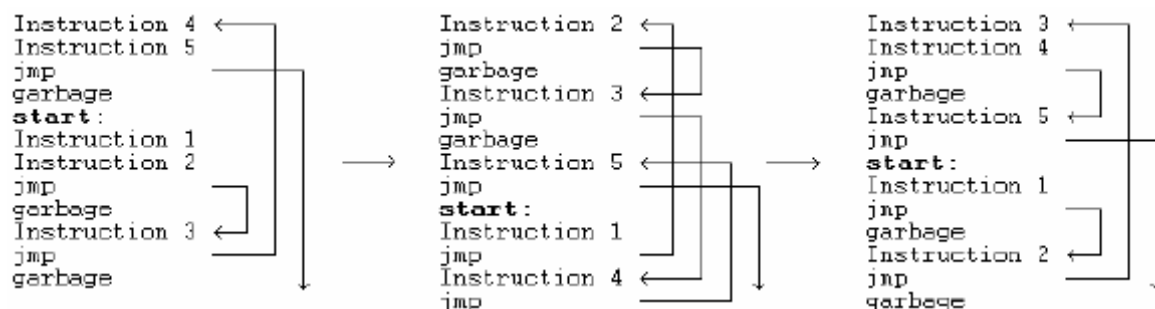
V následující ukázce (virus Win32/Evol) již sekvence nepomůžou. Jednotlivé generace vyjadřující jedno a to samé jsou odděleny prázdným řádkem.

```

C7060F000055 mov dword ptr [esi],5500000Fh
C746048BEC5151 mov dword ptr [esi+0004],5151EC8Bh
BF0F000055 mov edi,5500000Fh
893E mov [esi],edi
5F pop edi
52 push edx
B640 mov dh,40
BA8BEC5151 mov edx,5151EC8Bh
53 push ebx
8BDA mov ebx,edx
895E04 mov [esi+0004],ebx
BB0F000055 mov ebx,5500000Fh
891E mov [esi],ebx
5B pop ebx
51 push ecx
B9CB00C05F mov ecx,5FC000CBh
81C1C0EB91F1 add ecx,F191EBC0h ; ecx=5151EC8Bh
894E04 mov [esi+0004],ecx

```

Později se objevil virus Win95/Zperm, který navíc podobný kód prokládal „smetím“ (garbage), tedy nepotřebnými instrukcemi a dále skoky JMP, takže ani posloupnost nezůstala v každé generaci jednotná.

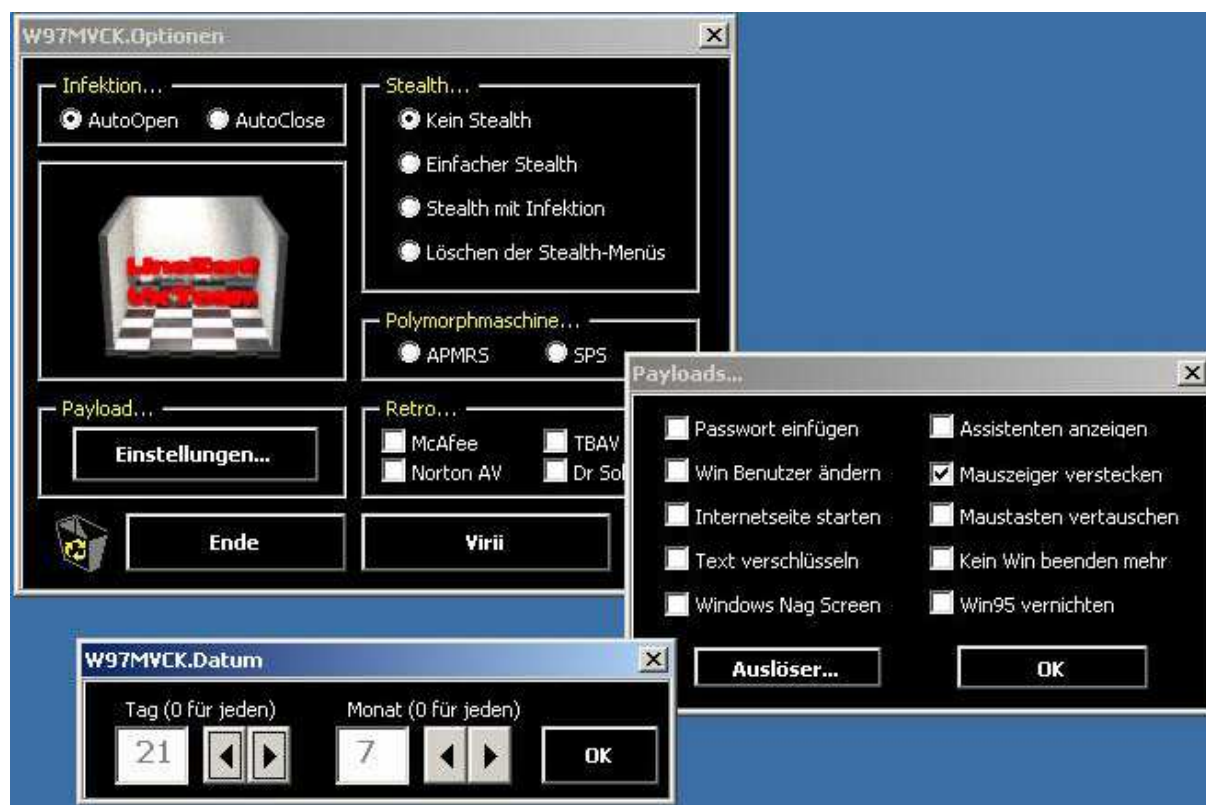


Obrázek - tři různé generace viru Win95/Zperm.

Navíc společně s tímto virem byl do oběhu vypuštěn Real Permutating Engine (RPME), na základě něhož se v budoucnu objevilo několik podobných virů. Samotnou kapitolu si určitě zaslouží virus Win95/Zmist, který byl na konferenci Virus Bulletin 2000 prezentován jako nejvíce „undetected virus“ a celkově je odborníky považován za to „nejlepší“, co se v celé historii počítačových virů objevilo. Z0mbieho (autor viru ze skupiny 29A) Mistfall engine obsažený ve viru Win95/Zmist totiž dokáže dekompileovat jakýkoliv PE soubor a vlastní kód viru proložit do původního programu! Jednotlivé instrukce viru jsou provázány skoky – instrukcemi JMP, takže nemusí být vizuálně za sebou (podobně jako Win32/Zperm). Z výše uvedeného je zřejmé, že dochází k obrovským změnám v původním kódu (i když významově představuje stále totéž) a následně musí dojít i k úpravě souvisejících záležitostí (data references...), aby byl nově vytvořený (zkompilovaný) PE soubor korektní. Nově vytvořený PE nevypadá jistě srozumitelně, ale společně s využitím techniky EPO a polymorfni dekryptovací smyčky rozdrobené na několik částí navzájem propojených instrukcemi skoku se stal pro některé antiviry opravdu nedetekovatelným³².

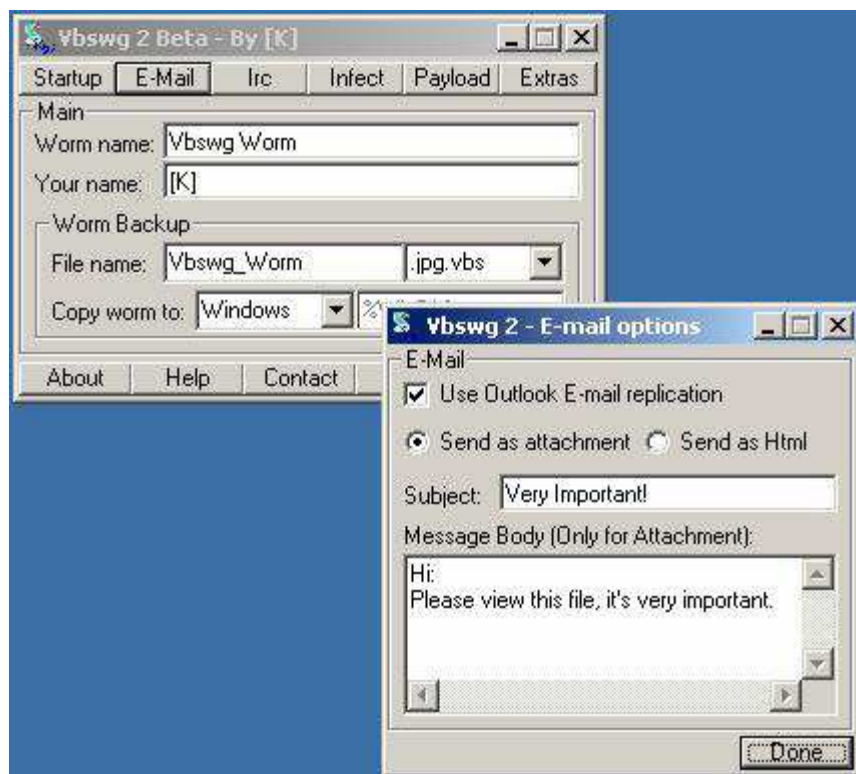
Generátory virů

Na Internetu lze najít řadu generátorů virů (nebo konstruktorů), tedy programů, které na základě požadavků uživatele dokážou vygenerovat hotový virus.



Obrázek - generátor W97MVCK pro tvorbu makrovirů.

Vytvořit virus tak může být hračkou i pro běžného uživatele. Stačí jen zatrhnout několik položek, vyplnit pár řádků a stisknout tlačítko, které virus dle požadavků vygeneruje. Jedním z nejstarších byl generátor VCL (z roku 1990) pro generování jednoduchých COM infektorů. Největší raritou pak byl pravděpodobně generátor V.G.O.L, jelikož byl jako jediný v podobě webových stránek! Autorem byla osoba „MadDeamon“ a tuto službu nabízel na serveru hysteria.sk. V dnešní době se většina generátorů zabývá skriptovými viry a makroviry. Samotný výstupní kód produkovaný generátorem musí být průběžně modifikován. Pro antivirovou společnost totiž není problémem zajistit 100% detekci všech virů, které různou kombinací přepínačů můžeme vygenerovat (často bývá název takového viru doplněn dovětkem .based).



Obrázek - V generátoru VBSWG vznikl i veleúspěšný virus VBS/SST.A - Anna Kurnikova !